

فلاي قাকা (Fly GACA) — إجراء الإشعار باختراق البيانات الشخصية بموجب PDPL

القسم legal-02 النوع legal الحالة draft المالك Founder آخر تحديث 14-06-2026

الوثيقة: pdpl-breach-notification-procedure-draft-2026-06-14.md الإصدار: مسودة 1.0 — 14-06-2026
الحالة: DRAFT — يتطلب مراجعة من محام سعودي مرخص ومؤهل قبل الاستخدام. الغرض: إجراء تشغيلي داخلي لتحديد حوادث أمن البيانات الشخصية واحتوائها وتقييمها والإشعار بها بموجب المادة 20 من نظام حماية البيانات الشخصية (PDPL) واللائحة التنفيذية للهيئة السعودية للبيانات والذكاء الاصطناعي. المالك: المؤسس / مسؤول حماية البيانات (عادل يحيى أ. مدخلي) التواصل: security@flygaca.com | privacy@flygaca.com

DRAFT — يتطلب مراجعة من محام سعودي مرخص ومؤهل قبل الاستخدام.

هذه الوثيقة مسودة عمل أعدها مساعد ذكاء اصطناعي لمراجعة المؤسس. وهي ليست استشارة قانونية. ويجب مراجعتها من محام سعودي مرخص (ذو خبرة في PDPL) قبل الاعتماد عليها تشغيلياً.

نقاط المراجعة الرئيسية: (1) تأكيد العتبة الدقيقة لإشعار الهيئة السعودية للبيانات والذكاء الاصطناعي بموجب المادة 20 من PDPL واللائحة التنفيذية — وبخاصة ما إذا كانت العتبة "يُرجَّح أن تسبب ضرراً جسيماً" وما إذا كان ذلك موصوفاً بصورة صحيحة في القسم 4 أدناه؛ (2) تأكيد قناة الإشعار الحالية للهيئة السعودية للبيانات والذكاء الاصطناعي، أو بوابتها، أو نموذج الإبلاغ لديها؛ (3) تأكيد ما إذا كان إشعار صاحب البيانات مطلوباً بموجب PDPL وإن كان كذلك، ففي أي ظروف وأي إطار زمني؛ (4) ما إذا كان هذا الإجراء كافياً كوثيقة منفصلة أم يحتاج إلى دمج في سياسة أمن المعلومات (compliance-ksa/information-security--04) (policy.docx)؛ (5) تأكيد الموقف بموجب لائحة الهيئة السعودية للبيانات والذكاء الاصطناعي بشأن سجلات الاختراق ومتطلبات التوثيق.

1. الغرض

يحدّد هذا الإجراء الخطوات التي ستتبعها فلاي قাকা عند اكتشاف حادث أمن بيانات شخصية ("اختراق"). وهو مصمّم لضمان:

- الكشف والاحتواء والتعافي السريع
- الامتثال لالتزام الإشعار خلال 72 ساعة للهيئة السعودية للبيانات والذكاء الاصطناعي بموجب المادة 20 من PDPL
- الإشعار في الوقت المناسب لأصحاب البيانات المتأثرين حيث يلزم
- التوثيق والتعلّم لمنع التكرار

ينطبق هذا الإجراء على جميع موظفي فلي قازا والمقاولين ومقدمي الخدمات من الأطراف الثالثة الذين يتعاملون مع البيانات الشخصية.

2. التعريفات

"البيانات الشخصية" تعني أي بيانات تؤدي إلى تحديد فرد بعينه أو تجعل تحديده ممكناً، كما هو معرّف في PDPL. "حادث أمني" يعني أي حدث ينتج أو قد ينتج عنه المساس بالبيانات الشخصية — بما في ذلك الوصول غير المصرّح به إلى البيانات الشخصية أو إفشاؤها أو تعديلها أو إتلافها، سواءً عمداً أو عرضاً. "اختراق واجب الإشعار" يعني حادثاً أمنياً يُرجّح أن يسبّب ضرراً جسيماً لأي صاحب بيانات، ويتطلب الإشعار إلى الهيئة السعودية للبيانات والذكاء الاصطناعي بموجب المادة 20 من PDPL. "مسؤول حماية البيانات (DPO)" (مسؤول/جهة التواصل لحماية البيانات): بالنسبة لفلي قازا في هذه المرحلة، يتصرّف المؤسس (عادل يحيى أ. مدخلي) بصفته المسؤول. التواصل: privacy@flygaca.com. "فريق الاستجابة للحوادث (IRT)": في النطاق الحالي، هو المؤسس إضافةً إلى أي مقاولين تقنيين متعاقد معهم أو جهة دعم الأمن السيبراني. [يُوشع عند تأسيس الكيان ونمو الفريق].

3. كشف الحادث والاستجابة الأولية

3.1 مصادر الكشف

قد تُكتشف الحوادث عبر:

- تنبيهات آلية من انتهاكات قواعد أمن Firebase، أو نشاط مصادقة غير معتاد، أو مراقبة أمن Cloudflare
- بلاغات من المستخدمين (عبر support@flygaca.com أو security@flygaca.com)
- بلاغات من المعالجين الفرعيين من الأطراف الثالثة (Google Firebase, Cloudflare, Moyasar)
- بلاغات من باحثي الأمن (عبر security@flygaca.com — انظر SECURITY.md)
- اكتشاف داخلي أثناء الفحوص الروتينية للنظام

3.2 الخطوات الفورية عند الاكتشاف

عند تحديد حادث أمني مشتبّه به، يجب على المكتشف:

الخطوة 1 — الإبلاغ فوراً. التواصل مع مسؤول حماية البيانات (المؤسس) بأسرع الوسائل المتاحة: security@flygaca.com أو رسالة مباشرة. لا تتأخّر للتحقيق بصورة مستقلة.

الخطوة 2 — حفظ الأدلة. لا تحذف السجلات أو التنبيهات أو سجلات النظام. احفظ جميع الأدلة التقنية المتاحة ذات الصلة بالحادث.

الخطوة 3 — الاحتواء الأولي. اتخذ خطوات فورية ومتناسبة لوقف الضرر الجاري — مثل تعطيل بيانات اعتماد وصول مخترقة، أو إبطال مفتاح واجهة برمجة تطبيقات (API) مكشوف، أو التعليق المؤقت للوصول إلى مخزن بيانات متأثر — دون إتلاف الأدلة.

الخطوة 4 — تسجيل وقت الاكتشاف. تبدأ ساعة الإشعار للهيئة السعودية للبيانات والذكاء الاصطناعي ومدتها 72 ساعة من لحظة علم فلامي قاكاً باختراق واجب الإشعار.

4. التقييم — هل هذا اختراق واجب الإشعار؟

4.1 العتبة

بموجب المادة 20 من PDPL، الاختراق الواجب الإشعار هو ما يُرجَّح أن يسبب ضرراً جسيماً لأصحاب البيانات. وقد تحدّد اللائحة التنفيذية للهيئة السعودية للبيانات والذكاء الاصطناعي معايير إضافية. [المحامي: يُرجى تأكيد العتبة التنظيمية الحالية وأي إرشادات صادرة عن الهيئة السعودية للبيانات والذكاء الاصطناعي].

4.2 مصفوفة تقييم الخطورة

سيقيّم مسؤول حماية البيانات الحادث إزاء العوامل التالية:

العامل	منخفض	متوسط	مرتفع — يُرجَّح وجوب الإشعار
حساسية البيانات	بيانات تقنية/استخدام فقط	بيانات الحساب (البريد، الاسم)	أرقام رخص الهيئة العامة للطيران المدني، سجلات الاختبارات، بيانات مرتبطة بالدفع
عدد أصحاب البيانات المتأثرين	10 >	100–10	100 <
طبيعة التعرض	داخلي فقط؛ لا وصول خارجي	وصول خارجي محتمل، غير مؤكد	وصول خارجي غير مصرّح به مؤكد
إمكانية الضرر	لا تُذكر	أثر سمعة محتمل	سرقة هوية، خسارة مالية، ضرر تنظيمي، أثر على سلامة الطيران
مدة التعرض	دقائق	ساعات	أيام أو أكثر

قاعدة القرار: إذا وقع التقييم العام في "مرتفع" في أي صف، و"متوسط أو مرتفع" في أغلبية الصفوف، فعامله كواجب الإشعار وانتقل إلى القسم 5 فوراً. وعند الشك، عامله كواجب الإشعار.

4.3 سيناريوهات محددة

السيناريو	واجب الإشعار؟	ملاحظات
كشف عرضي لعنوان بريد مستخدم واحد لمستخدم آخر	على الأرجح لا	ضرر منخفض — مع التوثيق
سوء إعداد Firebase يكشف محتويات قاعدة البيانات لقراءات غير مُصاحقين عليها	نعم	يُرجَّح كثيراً أن يكون واجب الإشعار — احتواء وإشعار فوراً

السيناريو	واجب الإشعار؟	ملاحظات
وصول غير مصرّح به إلى سجلات محادثات Captain Adel Al	على الأرجح نعم	سجلات محادثات الذكاء الاصطناعي بيانات شخصية؛ قد تتضمن استفسارات تنظيمية حساسة
اختراق بيانات دفع لدى Moyasar (معالج فرعي)	نعم (يطلق بلاغ Moyasar التزامنا)	يحتفظ Moyasar ببيانات البطاقات؛ تحتفظ فلاي قازا ببيانات وصفية للمعاملات؛ التنسيق مع Moyasar
فقدان أو سرقة حاسوب محمول لموظف يحتوي نسخة احتياطية محلية	يعتمد على البيانات	قيّم البيانات الموجودة وما إذا كانت مشفرة
حادث أمني لدى Cloudflare (مبلغ عنه من Cloudflare)	يعتمد على البيانات التي جرى الوصول إليها	اتبع بلاغ حادث Cloudflare وقمّ

5. الإشعار — الهيئة السعودية للبيانات والذكاء الاصطناعي (التزام الـ 72 ساعة)

5.1 الموعد النهائي

تتطلب المادة 20 من PDPL الإشعار إلى الهيئة السعودية للبيانات والذكاء الاصطناعي خلال 72 ساعة من علم فلاي قازا باختراق واجب الإشعار. وتسري ساعة الـ 72 من وقت الاكتشاف (الخطوة 4، القسم 3.2).

5.2 الجدول الزمني والإجراءات

الساعة	الإجراء	المالك
H+0	تأكيد الاكتشاف؛ حفظ الأدلة؛ بدء الاحتواء الأولي	المكتشف / مسؤول حماية البيانات
H+0 إلى H+4	إتمام تقييم الخطورة (القسم 4)	مسؤول حماية البيانات
H+4 إلى H+12	إذا كان واجب الإشعار: تقديم إشعار أولي للهيئة السعودية للبيانات والذكاء الاصطناعي (قد يكون جزئياً — انظر القسم 5.4)	مسؤول حماية البيانات
H+12 إلى H+48	إجراء تحقيق كامل؛ جمع معلومات إضافية	مسؤول حماية البيانات + الدعم التقني
H+48 إلى H+72	تقديم الإشعار الكامل للهيئة السعودية للبيانات والذكاء الاصطناعي (محدث أو تكميلي إذا قُدّم إشعار أولي)	مسؤول حماية البيانات
+H+72	التعامل المستمر مع الهيئة السعودية للبيانات والذكاء الاصطناعي؛ إشعار صاحب البيانات (إن لزم)؛ التعافي والمعالجة	مسؤول حماية البيانات

5.3 قناة الإشعار للهيئة السعودية للبيانات والذكاء الاصطناعي

[ملاحظة للمحامي: أُنذ قناة الإشعار بالاختراق الحالية للهيئة السعودية للبيانات والذكاء الاصطناعي — بوابة الهيئة، أو عنوان بريد، أو نموذج محدد — وحُدّ هذا القسم قبل إنهاء هذا الإجراء. وقت الصياغة، أعلنت الهيئة السعودية للبيانات والذكاء الاصطناعي آلية للإشعار بالاختراق؛ وينبغي للمحامي تأكيد طريقة التقديم المباشرة.]

بانتظار التأكيد: جهّز الإشعار للتقديم إلى:

- قناة الإشعار الرسمية للهيئة السعودية للبيانات والذكاء الاصطناعي: [يؤكد مع المحامي — أدرج بوابة/عنوان الإشعار بالاختراق الحالي للهيئة السعودية للبيانات والذكاء الاصطناعي]
- جهة تواصل احتياطية: الهيئة الوطنية للأمن السيبراني (NCA) إذا كان للاختراق أبعاد أمن سيبراني تتطلب إشعار الهيئة الوطنية للأمن السيبراني

5.4 محتوى الإشعار للهيئة السعودية للبيانات والذكاء الاصطناعي

يجب أن يتضمن الإشعار للهيئة السعودية للبيانات والذكاء الاصطناعي (بقدر المعروف):

1. تاريخ ووقت اكتشاف الاختراق
 2. طبيعة الاختراق (وصول / إفشاء / تعديل / إتلاف غير مصرّح به)
 3. فئات البيانات الشخصية المتأثرة
 4. العدد التقريبي لأصحاب البيانات المتأثرين (أو أفضل تقدير)
 5. طبيعة الضرر المرجّح لأصحاب البيانات
 6. التدابير المتخذة سلفاً لاحتواء الاختراق وتخفيفه
 7. التدابير المخططة لمنع التكرار
 8. بيانات التواصل لمسؤول حماية البيانات أو المسؤول
- إذا لم تتوفر كل المعلومات خلال 72 ساعة، فقدّم إشعاراً أولياً واستكمّله بأسرع ما يمكن. لا تؤخّر التقديم بعد 72 ساعة بانتظار اكتمال المعلومات.

5.5 متابعة الهيئة السعودية للبيانات والذكاء الاصطناعي

عقب الإشعار الأولي، قد تطلب الهيئة السعودية للبيانات والذكاء الاصطناعي مزيداً من المعلومات أو تصدر توجيهات، وسنُدار جميع تواصلات الهيئة السعودية للبيانات والذكاء الاصطناعي مباشرةً من مسؤول حماية البيانات وتسجّل في سجل الحوادث (القسم 8).

6. الإشعار — أصحاب البيانات المتأثرون

6.1 الالتزام

قد يتطلب PDPL إشعار أصحاب البيانات المتأثرين في ظروف معينة. [المحامي: يُرجى تأكيد التزام إشعار صاحب البيانات الحالي بموجب اللائحة التنفيذية للمادة 20 من PDPL — وبخاصة: (أ) ما إذا كان يُطلق بعتبة "الضرر الجسيم" نفسها؛ (ب) الإطار الزمني المطلوب؛ (ج) المحتوى المطلوب].

6.2 قالب إشعار مسودة

حيث يُطلَب إشعار صاحب البيانات، سيُكيّف القالب التالي للحدث المحدد:

الموضوع: إشعار مهم بشأن حسابك في فلاي قাকা — حادث أمني

نكتب إليك لإبلاغك بحادث أمني قد يكون أثر في معلوماتك الشخصية المحفوظة لدى فلاي قাকা.

ما حدث: [وصف بلغة واضحة للحادث — مثل "في [التاريخ]، اكتشفنا أن [صف الحادث بعبارات بسيطة]. احتوينا الحادث في [التاريخ]"]

ما المعلومات التي شملها: [اذكر فئات البيانات الشخصية المتأثرة — مثل الاسم، عنوان البريد الإلكتروني، بيانات تقدّم الدراسة، لا تُفرض في الإدراج أو التخمين.]

ما الذي فعلناه: [صف تدابير الاحتواء والمعالجة.]

ما الذي ينبغي أن تفعله: [خطوات محددة وعملية — مثل "نوصي بتغيير كلمة مرور فلاي قাকা فوراً. إذا كنت تستخدم كلمة المرور ذاتها في مكان آخر، فغيّرها في تلك الخدمات أيضاً" / "راقب بريدك بحثاً عن رسائل مشبوهة"]

تواصل معنا: إذا كانت لديك أسئلة عن هذا الحادث أو أردت ممارسة حقوقك في البيانات بموجب نظام حماية البيانات الشخصية، فتواصل معنا على: privacy@flygaca.com

نعتذر بصدق عن هذا الحادث. نحن نأخذ أمن بياناتك على محمل الجد ونلتزم بمنع التكرار.

فريق فلاي قাকা

6.3 قنوات الإشعار

لأصحاب الحسابات المسجلين: إشعار بالبريد الإلكتروني إلى عنوان البريد المسجل. لغير أصحاب الحسابات (إن انطبق): إشعار بارز على الموقع.

7. حوادث المعالجات الفرعية

7.1 تلقّي إشعار من معالج فرعي

إذا أبلغ معالج فرعي (Google Firebase, Cloudflare, Moyasar) عن حادث أمني يؤثر في بيانات فلاي قাকা:

- قيّم فوراً ما إذا كانت بيانات فلاي قাকা وأصحاب بياناتها متأثرين
- احصل على بلاغ الحادث من المعالج الفرعي
- اتبع الأقسام 3-6 من هذا الإجراء كما لو أن الحادث اكتُشف داخلياً
- تسري ساعة الـ 72 من وقت تلقّي فلاي قাকা إشعار المعالج الفرعي

7.2 قطاع الأعمال — إشعار عميل الأكاديمية

حيث يؤثر حادث أمني في بيانات شخصية تُعالج نيابةً عن عميل أكاديمية (بموجب اتفاقية معالجة بيانات لقطاع الأعمال)، أشعر عميل الأكاديمية (بصفته المراقب) خلال 48 ساعة وفقاً للقسم 6.1 من اتفاقية معالجة البيانات ذات الصلة. ويكون المراقب عندئذٍ مسؤولاً عن إشعاره الخاص للهيئة السعودية للبيانات والذكاء الاصطناعي حسب الاقتضاء.

8. سجل الحوادث والمراجعة بعد الحادث

8.1 سجل الحوادث

سيحتفظ مسؤول حماية البيانات بسجل مكتوب لكل حادث أمني، بصرف النظر عن كونه واجب الإشعار. ولكل حادث، يسجل السجل:

- تاريخ ووقت الاكتشاف
 - تاريخ ووقت الاحتواء
 - طبيعة الحادث
 - البيانات المتأثرة (الفئات وعدد السجلات)
 - أصحاب البيانات المتأثرون (العدد التقريبي)
 - ما إذا كان واجب الإشعار — وإن كان كذلك، تاريخ ومرجع إشعار الهيئة السعودية للبيانات والذكاء الاصطناعي
 - ما إذا أشعر أصحاب البيانات
 - إجراءات المعالجة المتخذة
 - السبب الجذري (بمجرد تحديده)
 - الدروس المستفادة والتدابير الوقائية المنقّدة
- هذا السجل وثيقة داخلية تُحفظ في legal-02 / أو موقع آمن معادل. وسيُتاح للهيئة السعودية للبيانات والذكاء الاصطناعي عند الطلب.

8.2 المراجعة بعد الحادث

خلال 30 يوماً من احتواء اختراق واجب الإشعار، سيجري مسؤول حماية البيانات مراجعةً بعد الحادث من أجل:

- تأكيد السبب الجذري
- تقييم كفاية الاستجابة
- تحديد التدابير الوقائية
- تحديث هذا الإجراء وسياسة أمن المعلومات (compliance-ksa-04 /) والضوابط التقنية حسب الحاجة

9. التدريب والتوعية

سيُطّلع جميع أعضاء الفريق ذوي الوصول إلى البيانات الشخصية على:

- كيفية التعرّف على حادث أمني محتمل
 - التزام الإبلاغ الفوري (القسم 3.2)
 - بيانات التواصل لمسؤول حماية البيانات (privacy@flygaca.com / security@flygaca.com)
- سيُراجع هذا الإجراء سنوياً ويُحدّث ليعكس التغييرات في اللائحة التنفيذية لـ PDPL أو إرشادات الهيئة السعودية للبيانات والذكاء الاصطناعي أو منصة فلاي قাকা.

10. الوثائق ذات الصلة

الوثيقة	الموقع
سياسة أمن المعلومات	compliance-ksa/information-security-policy.docx-04
برنامج الامتثال لـ PDPL وتقييم الأثر على حماية البيانات	compliance-ksa/pdpl-compliance-program-and-dpia.docx-04
سجل المعالجين الفرعيين	compliance-ksa/sub-processor-list-and-dpa-register.docx-04
اتفاقية معالجة البيانات لقطاع الأعمال	legal/b2b-data-processing-agreement-draft-2026-06-14.md-02
إشعار الخصوصية (المرحلة الكاملة)	legal/privacy-notice-full-stage-draft-2026-06-14.md-02
SECURITY.md (الإفصاح المسؤول)	governance/SECURITY.md-01

14-06-2026 — DRAFT 1.0. وثيقة داخلية. بانتظار مراجعة المستشار القانوني السعودي. الأولوية: يجب إنهاء هذا الإجراء وتأكيد قناة الإشعار للهيئة السعودية للبيانات والذكاء الاصطناعي قبل إطلاق الحساب. ساعة الـ 72 موعداً نظامي قطعي بلا مهلة سماح.